SURVEILLANCE PRÉVENTIVE EN CYBERSÉCURITÉ · LABO

Journaux de flux NetFlow/IPFIX

Configurer un exporteur, collecter des flux et mener une enquête sans le contenu des paquets

Élément	Détails
Durée prévue	Environ 2 h 15 (partie 1 : 30 min · partie 2 : 75 min · partie 3 : 30 min)
Environnement	Votre environnement isolé du Cyber Range : VM pfSense (10.0.0.1) et VM Kali (10.0.0.2, interface eth0)
Fichiers fournis	`enquete.pcap.gz` (jeu d'enquête) · `enquete_flux.tar.gz` (flux déjà convertis, en secours) · `analyse_beacon.py`
Remise	Un rapport (Word ou PDF) contenant vos réponses aux questions, la chronologie et vos règles de détection

Objectifs

- Configurer un exporteur de flux (softflowd sur pfSense) et un collecteur (nfcapd sur Kali).
- Lire et interroger des flux avec nfdump : filtres, statistiques, fenêtres de temps.
- Reconnaître dans des flux un balayage, une force brute, un mouvement latéral, un beaconing, un tunnel DNS et une exfiltration.
- Reconstituer la chronologie d'un incident et traduire vos constats en règles de détection.

> **Règles du labo**
> Toutes les manipulations se font dans votre environnement isolé du Cyber Range. Ne lancez aucun balayage ni aucune attaque vers une adresse extérieure à cet environnement.
> Dans la partie 2, n'ouvrez pas le fichier pcap dans Wireshark avant la question bonus : le but est d'enquêter avec les flux seulement.

Partie 1 — Mettre en place l'export de flux (30 min)

Dans cette partie, votre pfSense devient l'**exporteur** et votre VM Kali le **collecteur**. Vous observerez ensuite votre propre trafic sous forme de flux.

1.1 Préparer le collecteur sur Kali

Dans votre environnement, les adresses sont toujours les mêmes : la Kali est **10.0.0.2** (interface **eth0**) et le pfSense est **10.0.0.1**. Ouvrez un terminal sur Kali et démarrez nfcapd. Laissez ce terminal ouvert pendant toute la partie 1.

```
sudo apt install -y nfdump      # si nfdump n'est pas déjà installé
mkdir -p ~/flux_direct
nfcapd -w ~/flux_direct -p 2055
```

nfcapd écoute sur le port UDP 2055 (`-p`) et écrit les flux reçus dans le dossier `~/flux_direct` (`-w`).

1.2 Configurer softflowd sur pfSense

1. Dans Firefox sur Kali, ouvrez `http://10.0.0.1` (ou tapez simplement `10.0.0.1` dans la barre d'adresse). Le pfSense n'accepte pas les connexions sur le port 443 : `https://` ne fonctionne pas. Connectez-vous avec **admin / pfsense**, à moins que vous ayez déjà changé le mot de passe.
2. Allez dans **System > Package Manager > Available Packages**, cherchez **softflowd** et installez-le.
3. Allez dans **Services > softflowd** et configurez le service selon le tableau ci-dessous, puis cliquez sur **Save**.

Paramètre	Valeur	Pourquoi
Enable	Coché	Active le service
Interface	LAN	Observer le trafic avant le NAT, avec les vraies adresses internes
Host	10.0.0.2	Adresse de la Kali : destination des enregistrements (le collecteur)
Port	2055	Port d'écoute de nfcapd
NetFlow version	10 (IPFIX)	Le standard ouvert vu en classe
Flow tracking level	Full	Conserver le 5-tuple complet
Bidirectional Flow	Décoché	Un enregistrement par sens, comme vu en théorie

> **Connexion impossible ou mot de passe oublié ?**
> Ouvrez la console de la VM pfSense à partir d'OpenNebula, puis choisissez l'option **3) Reset admin account and password**. Le compte redevient admin / pfsense.

1.3 Vérifier la réception

Dans un deuxième terminal sur Kali, écoutez le port 2055 sur l'interface eth0 :

```
sudo tcpdump -ni eth0 udp port 2055
```

Rien ne s'affiche pour l'instant ? C'est normal : softflowd attend que les flux **expirent** avant de les envoyer. Passez à l'étape suivante.

1.4 Générer du trafic et forcer l'export

Naviguez sur deux ou trois sites, puis lancez ces commandes sur Kali :

```
dig example.com
curl -sI https://example.com
```

Commande	Ce qu'elle fait
`dig example.com`	Interroge le serveur DNS (ici le pfSense, 10.0.0.1) pour obtenir l'adresse IP d'example.com, et affiche la réponse détaillée. Elle produit une requête et une réponse DNS, sans connexion au site.
`curl https://example.com`	Se connecte au site en HTTPS et télécharge la page, comme un navigateur sans interface. curl résout d'abord le nom, puis ouvre une connexion TCP vers le port 443.
`-s` (silent)	Mode silencieux : pas de barre de progression ni de message d'erreur.
`-I` (head)	Envoie une requête HEAD au lieu de GET : le serveur renvoie seulement les en-têtes (code HTTP, type de contenu…), sans la page. Les volumes échangés restent donc faibles.

Forcez ensuite l'export des flux en cache. Dans pfSense, ouvrez **Diagnostics > Command Prompt** (ou l'option **8) Shell** de la console) et exécutez :

```
ls /var/run | grep softflowd          # repérer le socket de contrôle (.ctl)
softflowctl -c /var/run/<socket>.ctl statistics
softflowctl -c /var/run/<socket>.ctl expire-all
```

Des paquets doivent maintenant apparaître dans tcpdump. nfcapd écrit dans un fichier temporaire qu'il renomme toutes les **5 minutes** : attendez la rotation, puis interrogez vos flux.

```
nfdump -R ~/flux_direct -o long -O tstart
nfdump -R ~/flux_direct -o long -O tstart 'port 443'
```

Élément	Rôle
`-R ~/flux_direct`	Lire tous les fichiers de flux du dossier.
`-o long`	Afficher une ligne lisible par flux : heure, durée, protocole, adresses et ports, drapeaux TCP, paquets, octets. Sans cette option, nfdump affiche des colonnes de pare-feu Cisco qui ne veulent rien dire ici.

Élément	Rôle
`-O tstart`	Trier les flux par heure de début. Sans cette option, ils sortent dans l'ordre où ils ont été écrits, ce qui mélange la chronologie. Ajoutez-la à presque toutes vos commandes.
`'port 443'`	Un filtre, toujours entre apostrophes et à la fin : il choisit quels flux afficher (ici, ceux qui utilisent le port 443).

1.5 Isoler une seule commande

Pour observer les flux d'une seule action, il faut un dossier de collecte propre et aucun autre trafic. Fermez Firefox, puis arrêtez le nfcapd de l'étape 1.1 (Ctrl+C dans son terminal) et relancez-le dans un nouveau dossier :

```
mkdir -p ~/flux_curl
nfcapd -w ~/flux_curl -p 2055
```

Sur pfSense, videz le cache de softflowd avec `expire-all`. Sur Kali, lancez ensuite cette commande, qui affiche l'heure, puis l'adresse et le port de chaque côté de la connexion :

```
date +%T; curl -sI -o /dev/null \
  -w '%{local_ip}:%{local_port} -> %{remote_ip}:%{remote_port}\n' https://example.com
```

Élément	Rôle
`date +%T`	Affiche l'heure actuelle (heures:minutes:secondes) pour retrouver le moment de la connexion.
`;`	Enchaîne deux commandes sur la même ligne : `date`, puis `curl`.
`-sI`	Mode silencieux et requête HEAD (en-têtes seulement), comme à l'étape 1.4.
`-o /dev/null`	Jette la réponse du serveur au lieu de l'afficher : seule la ligne de `-w` reste à l'écran.
\ (fin de ligne)	Indique au shell que la commande continue à la ligne suivante.
`-w '…'`	Après le transfert, affiche le texte entre apostrophes en remplaçant chaque variable `%{…}` par sa valeur.
`%{local_ip}:%{local_port}`	L'adresse et le port source utilisés par la Kali (port éphémère choisi au hasard).
`%{remote_ip}:%{remote_port}`	L'adresse et le port du serveur réellement contacté (example.com, port 443).
`\n`	Saut de ligne à la fin, pour que l'invite du terminal revienne à la ligne.

Exemple de sortie : `16:51:48` puis `10.0.0.2:53154 -> 172.66.147.243:443`. Notez-la. Forcez de nouveau `expire-all` sur pfSense, attendez la rotation de nfcapd (5 minutes au plus), puis répondez aux questions.

Questions — partie 1

Q1a. Retrouvez les flux de la connexion HTTPS à l'aide du port source affiché par curl : `nfdump -R ~/flux_curl -o long -O tstart 'port <port_source>'`. Combien d'enregistrements obtenez-vous, et pourquoi ce nombre ?

Q1b. Avant de se connecter, la Kali a dû trouver l'adresse d'example.com. Retrouvez les flux de cette étape. Indice : ils ne concernent pas l'adresse d'example.com. Quelle commande nfdump avez-vous utilisée ?

Q1c. Combien d'enregistrements la commande curl a-t-elle produits au total ? Les flux DNS contiennent 2 paquets alors que curl n'a cherché qu'un seul nom : expliquez pourquoi (pensez au 5-tuple).

Q2. Pour la connexion HTTPS, comparez les octets des deux sens. Qui envoie le plus de données ? Est-ce cohérent avec ce que fait la commande ?

Q3. Pourquoi avez-vous dû forcer l'export (ou attendre) avant de voir vos flux ? Faites le lien avec les délais d'expiration vus en classe.

Q4. Les adresses source de vos flux sont-elles celles de Kali ou l'adresse WAN du pfSense ? Que verriez-vous si softflowd observait l'interface WAN ?

Q5. Lancez la boucle ci-dessous, forcez l'export, puis retrouvez ces connexions dans vos flux (`~/flux_curl`). Quelle régularité observez-vous ? En quoi ressemble-t-elle à un beacon ?

```
for i in $(seq 1 10); do curl -s -o /dev/null https://example.com; sleep 15; done
```

Partie 2 — Enquête « Logistique Gatineau » (75 min)

Mise en situation

Logistique Gatineau inc. est une entreprise fictive de transport. Le jeudi 15 octobre 2026 au matin, son fournisseur Internet signale qu'une grande quantité de données est sortie de son réseau **la veille au soir**, vers une adresse inconnue.

L'entreprise n'a ni EDR ni capture complète. La seule source disponible : les **flux du mercredi 14 octobre**, produits par une sonde branchée sur le port miroir du commutateur central. Cette sonde voit donc aussi le trafic entre les machines internes. Vous êtes l'analyste de garde : reconstituez ce qui s'est passé.

Inventaire du réseau (10.0.0.0/24)

Adresse	Rôle
10.0.0.1	Pare-feu pfSense : passerelle et résolveur DNS interne (le seul DNS autorisé)
10.0.0.10	SRV-FICHIERS : serveur Windows de partages de fichiers (SMB)
10.0.0.11	SRV-LINUX : serveur d'applications Linux, administré en SSH
10.0.0.101 à 10.0.0.109	Postes de travail des employés
10.0.0.110	Poste de l'administrateur TI
192.0.2.123	Serveur de temps (NTP) officiel de l'entreprise

Heures normales de travail : de 8 h à 17 h 30. Les postes sont habituellement éteints le soir.

2.1 Préparer les données

Travaillez dans un **nouveau dossier**, séparé de vos flux de la partie 1. Copiez les fichiers fournis dans votre dossier personnel, puis :

```
export TZ=America/Toronto                    # heure de Gatineau
gunzip enquete.pcap.gz
mkdir -p ~/enquete
nfpcapd -r enquete.pcap -w ~/enquete -t 3600  # convertit le pcap en flux
nfdump -R ~/enquete -s proto/flows
```

Avec nfpcapd, `-t 3600` découpe les flux en fichiers d'une heure (24 fichiers pour la journée) au lieu de 5 minutes par défaut. Ça ne change rien aux résultats : `nfdump -R` lit tout le dossier.

Trois pièges à éviter

Le même -t, deux sens. Pour nfpcapd et nfcapd, `-t` est la durée de chaque fichier, en secondes (`-t 3600`). Pour nfdump, `-t` est la fenêtre de temps à afficher (`-t '2026/10/14.17:30-2026/10/14.23:59'`).

Le fuseau horaire. nfdump affiche les heures selon le fuseau de la machine. Sans `export TZ=America/Toronto` (à refaire dans chaque nouveau terminal), toutes vos heures seront décalées.

Si nfpcapd n'est pas disponible, utilisez les flux déjà convertis : `tar xzf enquete_flux.tar.gz -C ~` crée le dossier `~/enquete`.

2.2 Boîte à outils nfdump

Besoin	Syntaxe
Lire un dossier de flux	`nfdump -R ~/enquete`
Afficher une ligne par flux, triée par heure	`-o line -O tstart`
Statistiques « top N »	`-s srcip/flows` · `-s dstip/bytes` · `-s dstport/flows` · `-n 10`
Limiter à une fenêtre de temps	`-t '2026/10/14.17:30:00-2026/10/14.23:59:59'` (seuls les flux entièrement compris dans la fenêtre)
Flux commencés après une heure donnée	`'first seen >= 2026-10-14T17:30'` (dans le filtre)
Regrouper les morceaux d'une même connexion	`-a`
Filtrer par adresse ou réseau	`'src ip 10.0.0.101'` · `'dst net 10.0.0.0/24'` (réseau aligné sur son masque)
Filtrer par protocole ou port	`'proto udp and dst port 53'`
Filtrer par drapeaux TCP	`'flags S and not flags A'` (SYN sans ACK)
Filtrer par volume	`'bytes > 1000000'` · `'packets < 3'`
Combiner	`and` · `or` · `not` · parenthèses

Exemple : `nfdump -R ~/enquete 'src ip 10.0.0.101 and dst port 443' -o line -O tstart | head`

Questions — partie 2

Pour chaque question, notez dans votre rapport la ou les **commandes utilisées** et les **flux qui appuient votre réponse** (heure, adresses, ports, volumes).

Vue d'ensemble et ligne de base

Q6. Combien de flux contient le jeu de données et quelle période couvre-t-il ? Quelles sont les cinq adresses qui génèrent le plus de flux ? Laquelle se démarque, et pourquoi est-ce étonnant ?

Q7. Établissez la ligne de base, c'est-à-dire le trafic **normal** du réseau. Répondez à quatre questions : quels services internes sont utilisés, et par qui (DNS, SMB, SSH…) ? Quels services Internet ? Vers quelles destinations ? Quels volumes, et à quelles heures ? Résumez le résultat dans un tableau.

> **Méthode**
> **Retirez ce que vous soupçonnez déjà** : excluez le poste repéré à Q6 avec `not host <adresse>`. Pour les volumes, limitez-vous aux heures de travail avec `'first seen >= 2026-10-14T08:00 and first seen < 2026-10-14T17:30'` dans le filtre.
> **Une ligne par couple « qui parle à quel service »** : `-A srcip,dstip,dstport -O flows` (sans `-o line`).
> **Les postes de travail** forment le réseau `10.0.0.96/27` (de .96 à .127) ; **les serveurs internes**, `10.0.0.0/28` (de .0 à .15). Un trafic vers Internet se filtre avec `not dst net 10.0.0.0/24`.

Le déroulement de l'attaque

Q8. Reconnaissance. Trouvez les traces de découverte d'hôtes et de balayage de ports. Précisez la source, les cibles, l'heure, la durée et le nombre de ports sondés. Quels ports ouverts l'attaquant a-t-il découverts ? (Indice : le scanner garde le même port source ; cherchez les réponses vers ce port qui contiennent un SYN.)

Q9. Accès initial. Montrez qu'il y a eu une force brute SSH : nombre de tentatives, intervalle, taille typique d'une tentative. Y a-t-il une tentative réussie ? Sur quels indices vous appuyez-vous ? Pourquoi cette session apparaît-elle en plusieurs enregistrements ?

Q10. Mouvement latéral. Quelles connexions SMB ou RDP partant du poste suspect sont anormales par rapport à votre ligne de base ? Donnez les cibles, les heures et les volumes.

Q11. Commande et contrôle. Une destination externe est contactée à intervalle régulier. Lancez le script fourni, puis répondez : quelle est la destination, l'intervalle moyen, la gigue, la taille des connexions, l'heure de début et de fin ? Pourquoi les flux NTP arrivent-ils en tête du classement, et pourquoi ne sont-ils pas suspects ?

```
python3 analyse_beacon.py ~/enquete
```

Q12. Tunnel DNS. Trouvez les requêtes DNS qui ne passent pas par le résolveur interne. Combien y en a-t-il, sur quelle période, et quelle est leur taille moyenne comparée à une requête DNS normale du réseau ? Pourquoi est-ce suspect ?

Q13. Exfiltration. Quel hôte interne a envoyé le plus de données vers l'extérieur en dehors des heures de travail ? Vers où, quand et combien ? Est-ce normal pour cet hôte ? Comment l'attaquant y avait-il accès à cette heure-là ?

Bonus. Ouvrez maintenant `enquete.pcap` dans Wireshark. Retrouvez le nom de domaine du serveur de commande et contrôle et la zone DNS utilisée par le tunnel. Pourquoi dit-on que « le flux indique où regarder, le pcap confirme » ?

Partie 3 — Livrables (30 min)

A. Chronologie de l'incident

Présentez l'incident dans un tableau, du premier signe suspect jusqu'à l'exfiltration. Chaque ligne doit s'appuyer sur au moins un flux précis.

Heure	Source → destination	Comportement	Preuve (commande ou flux)	ATT&CK
hh:mm:ss	…	…	…	Txxxx

B. Trois règles de détection

Proposez trois règles qui auraient permis de détecter cet incident plus tôt. Pour chacune, indiquez :

- le **filtre nfdump** ou la méthode (par exemple le script de beaconing) ;
- le **seuil** retenu et la fenêtre de temps ;
- au moins un **faux positif probable** et la façon de le réduire.

C. Recommandations

Proposez trois recommandations concrètes : confinement immédiat, durcissement, et amélioration de la visibilité. Pensez aux angles morts vus en classe.

Barème indicatif

Section	Pondération
Partie 1 — Export de flux et questions Q1 à Q5	20 %
Partie 2 — Enquête, questions Q6 à Q13	50 %
Partie 3 — Chronologie, règles et recommandations	30 %
Bonus — Confirmation dans le pcap	+5 %

Partie 4 — À venir : attaques en direct

Dans un prochain labo, vous générerez vous-mêmes des attaques depuis Kali vers la VM Metasploitable 3 et vous les retrouverez dans les flux exportés par votre pfSense. Conservez votre configuration softflowd.